

Password + Credential Policy

Version: v1.0 ADOPTED **Adopted:** 2026-07-21 by Sami Ben Chaalia (Security Officer) **Date:** 2026-07-21 **Owner:** Security Officer (Sami Ben Chaalia) **Framework mapping:** SOC 2 CC6.1 (Logical access) · CC6.2 (New user provisioning + deprovisioning) · HIPAA §164.308(a)(5)(ii)(D) password management · NIST SP 800-63B (Authenticator standards) **Companion documents:** Access Control Policy · Access Review Policy · Confidentiality Policy · Encryption Policy §4.

1. Purpose

State the human-side hygiene for every credential a RailCall operator holds. Complements Access Control Policy §6 (which lists WHERE access lives) with rules about HOW the credentials to that access are handled.

2. Scope

Every credential an operator uses to reach a system in Access Control Policy §6 or Vendor Management Policy §3. Covers passwords, SSH keys, API keys, OAuth tokens, TOTP secrets, hardware token seeds — anything that authenticates a person.

Out of scope: agent-to-system credentials (Ed25519 install seeds, blind api_key hashes) — those are covered in Encryption Policy §4.

3. The rules

3.1 Password manager is mandatory

1Password is the RailCall-standard password manager. Every operator uses it for:

- Every login the operator holds for RailCall-related systems.
- Every API key the operator generates for personal use of a RailCall-related service.
- Every SSH private key file (encrypted 1Password secret note, not just filesystem 0600).
- The issuer signing seed (see Encryption Policy §4.2 for the full ceremony).

Rationale: browser-cached passwords + local files + reused mental passwords each fail differently. 1Password consolidates the failure modes into one (the master passphrase), which is the failure mode we can most reliably defend.

3.2 Master passphrase requirements

- **Length $\geq$ 20 characters OR $\geq$ 5 words** if a passphrase.
- **Not a variation of any password used elsewhere.** Ever.
- **Not written down anywhere except:** one sealed paper copy in Sami's physical safe (offline recovery backup only).
- **Not typed in front of a camera** — Zoom, Loom, screen shares.
- **Rotated on any suspicion of exposure.** Not on a schedule (per NIST 800-63B guidance — rotation without cause weakens more than it strengthens).

3.3 MFA everywhere

Every account that supports MFA has it enabled. No exceptions for "just this one dev thing" — that's exactly the account that gets compromised.

Preferred MFA methods, ranked:

1. **Hardware token** (YubiKey via WebAuthn) — bind to the physical device the operator carries.
2. **TOTP in 1Password** (or a dedicated authenticator app) — the code is derived from a secret 1Password holds, so losing the phone doesn't lose access as long as the 1Password vault is intact.
3. **TOTP in Authy or Google Authenticator** — acceptable but weaker (single-device by default).
4. **SMS MFA** — NOT acceptable except as a fallback for services that offer nothing else. SIM-swap attacks are the classic bypass.
5. **Email MFA** — same as SMS; acceptable only when the target service offers nothing else.

Enabled today (baseline to maintain):

- GitHub org: MFA required for org members.
- Render: MFA on Sami's account; enforce for team on quarterly access review.
- Stripe: MFA required for all team members.
- 1Password: MFA required (device authorization + TOTP).
- Anthropic Console: MFA on Sami's account.
- DigitalOcean: MFA on Sami's account.
- Cloudflare: MFA required.

3.4 No password reuse

Each service gets a unique, generated password. 1Password's generator produces them; operators do not invent their own.

If the same password appears twice across services in the vault: treat as an incident (SEV-3), rotate both immediately.

3.5 API keys — scoped, dated, rotated

Every API key issued to an operator (Stripe restricted key, Anthropic key, GitHub PAT, etc.):

- **Named** for its purpose, dated by creation. `"RailCall - Stripe price setup - 2026-07-21"`.
- **Scoped** to the minimum permissions the task requires. Restricted keys > standard keys.
- **Rotated** on any suspicion of exposure, when the task ends, or annually — whichever first.
- **Revoked** immediately when the task ends if it was a task-scoped key.
- **Never checked into git.** `.gitignore` guards; leak gate in station release catches secondary paths.

Standing keys (persist beyond one task):

- Render `RAILCALL_ISSUER_SEED` — the trust root; rotation ceremony per Encryption Policy §7.
- Stripe standard secret key — rotates only on suspicion of compromise; standing because it's how the webhook + provisioning endpoint work.
- Anthropic API key for Probo — dev-scoped, rotates on operator change.

Task-scoped keys expected lifespan: hours to days. Standing keys: months to years.

3.6 SSH keys

- **Ed25519 preferred** (`ssh-keygen -t ed25519 -C "operator@date"`).
- **Passphrase-protected.** No naked private keys on disk. Passphrase stored in 1Password, entered via ssh-agent.
- **One key per operator per purpose.** Sami's VPS key (`~/ .ssh/id_ed255199`) is separate from Sami's GitHub key, separate from Sami's server admin key.
- **Rotation:** on operator device change, on suspicion of compromise, or annually — whichever first.
- **Revocation:** remove from every `authorized_keys` file the key was granted to. Access Review Policy §4.1 catches drift.

3.7 OAuth tokens + third-party session tokens

- Sessions to admin consoles (Render, Stripe, GitHub) expire per each service's default; operators do not extend session lifetime.
- OAuth tokens issued by any service that supports scoped issuance get minimum scope.

- Bookmarks + saved sessions on the operator's browser respect 1Password's autofill — the operator does NOT save the login in the browser's own manager (Chrome/Safari/Firefox password managers are OFF-limits for RailCall credentials).

3.8 Recovery + fallback

Every credential has a defined recovery path:

- **1Password vault:** master passphrase + emergency kit (paper copy in Sami's safe). Recovery from device loss requires the emergency kit.
- **MFA device:** each service's backup codes stored in 1Password.
- **SSH keys:** paper copy of the recovery instructions (which servers, which `authorized_keys` files) in Sami's safe. NOT paper copy of the private key — the paper is instructions to regenerate + re-authorize.
- **Issuer signing seed:** the seed itself is in Sami's paper safe + 1Password. This is the ONE credential we back up in its raw form because losing it is existential (see BC/DR Policy §5.1).

Every recovery path is tested at least once per year (annual issuer-seed rotation exercises the SEED path; scheduled password-manager restore drills exercise the MFA + SSH paths).

4. Provisioning + deprovisioning

- **New operator joins the team:** 1. 1Password shared vault invite. 2. GitHub org invite + MFA verification. 3. Render team invite + MFA verification. 4. Stripe team invite + MFA verification. 5. VPS SSH key added to appropriate `authorized_keys`. 6. Access Control Policy + Acceptable Use Policy signed (Probo). 7. Read this policy + acknowledge. 8. Documented in Access Control Policy §6.
- **Operator leaves:** 1. Every credential revoked (per Access Review Policy §5). 2. 1Password shared vault access removed. 3. Personal 1Password vault stays (their property). 4. NDA remains in effect for its term per Confidentiality Policy §11. 5. Documented in Access Control Policy §6 with revocation date.

5. Prohibited practices

Restating the sharp lines:

- **Sharing credentials.** No, not even between Sami and Pat. Each operator uses their own account with their own MFA.
- **Reusing personal passwords for work.** No — 1Password removes the excuse.

- **Storing credentials in text files, Signal messages, or GitHub issues.** No, ever. If a credential lands in a text channel by accident (§Acceptable Use §3.3): rotate + incident.
 - **Turning off MFA "just for this session".** No. If MFA is broken, fix MFA, don't disable it.
 - **Skipping 1Password because "this one is fine to remember".** No — the exception becomes the norm within a quarter.
-

6. Review

- **Per-credential:** at the cadence in Access Review Policy §3 (mostly quarterly for high-blast, annually for lower).
 - **This policy:** at each station release + at least annually.
 - **1Password vault contents:** scanned quarterly for reused passwords + stale entries; monthly for anomalous new entries.
-

7. Related documents

- **Access Control Policy §6** — the systems this policy's credentials reach.
- **Access Review Policy §3** — the cadence for reviewing who holds each of these credentials.
- **Encryption Policy §4** — the SoT-vs-copy story for the load-bearing secrets (issuer seed, install seed).
- **Acceptable Use Policy §3.3** — the operator-conduct rule that says secrets never go in text.
- **Confidentiality Policy §2** — the SECRET class that most of the credentials in §3.5 fall into.
- **BC/DR Policy §5.1, §5.8** — the recovery runbooks that assume §3.8 is in force.